الثغرة الاولى Rate Limiting & Brute Force :

اسم المشكلة	Brute Force / Rate Limiting Vulnerability
مستوى الخطورة	مرتفع (High) - لأن ترك نقطة تسجيل الدخول بلا حدود يتيح للمهاجمين تخمين كلمات المرور بلا توقف
المكان	مسار تسجيل الدخول `/api/auth/login` في ملف `app.js`
طريقة الاختبار	استخدام Postman لتكرار طلبات إرسال بيانات الدخول أكثر من 5 مرات متتالية بشكل سريع
النتيجة قبل الإصلاح	كان السيرفر يقبل عددًا لا نهائيًا من المحاولات، مما يعرض حسابات المستخدمين لخطر هجمات التخمين
طريقة المعالجة	دمج مكتبة `express-rate-limit` وتحديد الحد الأقصى بـ 5 محاولات لكل 15 دقيقة على مسار الـ login.
النتيجة بعد الإصلاح	أصبح الاختبار مرفوضاً عند تجاوز الحد المسموح، ويرجع النظام كود الاستجابة 429 `Too Many Requests`

الثغرة الثانية : معالجة الاخطاء/ اخفاء ال Stack Trace

اسم المشكلة	Information Disclosure / Stack Trace Leakage
مستوى الخطورة	متوسط (Medium) - لتجنب تسريب تفاصيل تقنية حساسة عن بنية النظام للمستخدم
المكان	errorHandler.js وسيط معالجة الأخطاء
طريقة الاختبار	إحداث خطأ متعمد في السيرفر أو طلب مسار غير موجود (/api/not-found) عبر Postman
النتيجة قبل الإصلاح	احتمالية ظهور مسارات الملفات الداخلية أو أخطاء قاعدة البيانات للمستخدم مباشرة
طريقة المعالجة	توحيد الاستجابة بـ errorHandler وإرسال رسالة خطأ آمنة ومبسطة (Internal server error) مع طباعة التفاصيل في الـ Terminal للمطور فقط.
النتيجة بعد الإصلاح	أصبحت استجابات الأخطاء نظيفة، موحدة، وآمنة وخالية من أي تسريب معلوماتي